Unauthenticated Password Reset leading to Account Takeover (forgot-password.php)

SHOP-011 — Vulnerability Assessment Finding Report

Field	Value
Finding ID	SHOP-011
Product	PHPGurukul Online Shopping Portal
Version	V2.0 package (product page labelled V2.1); SQL dump dated 2025-01-02
Developer	Anuj Kumar / PHPGurukul
Assessment Target	http://localhost:8080/shopping/ (authorized local laboratory; localhost only)
Assessment Date	2026-11-01
Severity	High
CVSS	8.1 / CVSS:4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N
CWE	CWE-640 (Weak Password Recovery)
OWASP	A07:2021 Identification & Authentication Failures
CVE Verification	No matching publicly assigned CVE was identified for this specific finding/version during the research performed. (No matching CVE (potentially novel))
Affected URL	http://localhost:8080/shopping/forgot-password.php
Affected Parameter	email, contact, password (POST)
Affected Role	Unauthenticated
Authentication	None

Executive Summary

Any account's password can be reset by anyone who supplies the account's email and contact number — there is no reset token, email verification, or current-password check. The inputs are also SQL-injectable.

Technical Description

forgot-password.php (line 11,16): verifies SELECT * FROM users WHERE email='$email' and contactno='$contact', then update users set password='md5(new)' WHERE email='$email' and contactno='$contact'. Gating a password change on guessable PII (and injectable fields) allows takeover; email=' OR '1'='1' -- - would reset every user.

Root Cause Analysis

Knowledge-based reset without a secret token; no proof of mailbox ownership; SQL-injectable.

Preconditions

Knowledge of the victim's email + contact number (both frequently known/enumerable; contactno is also exposed via SHOP-003/006).

Proof of Concept — Step-by-Step Reproduction

1. (Controlled, on a disposable account) Register vaptdisposable@test.local / contact 1234509876.
2. Without logging in, POST to forgot-password.php: email=<that>, contact=<that>, password=HackedByVapt9, change=.
3. The DB password hash becomes md5('HackedByVapt9'). Log in with the new password — success ('Welcome

-VAPT Disposable').

4. The disposable account was then deleted. The destructive SQLi mass-reset variant was NOT executed.

HTTP Request

```
POST /shopping/forgot-password.php HTTP/1.1
Host: localhost:8080
Content-Type: application/x-www-form-urlencoded

email=vaptdisposable%40test.local&contact=1234509876&password=HackedByVapt9&change=
```

HTTP Response (evidence)

```
HTTP/1.1 302 (Password Changed Successfully) ; subsequent login with the new password -> 302 my-cart.php (authenticated)
```

Proof of Concept & Visual Evidence

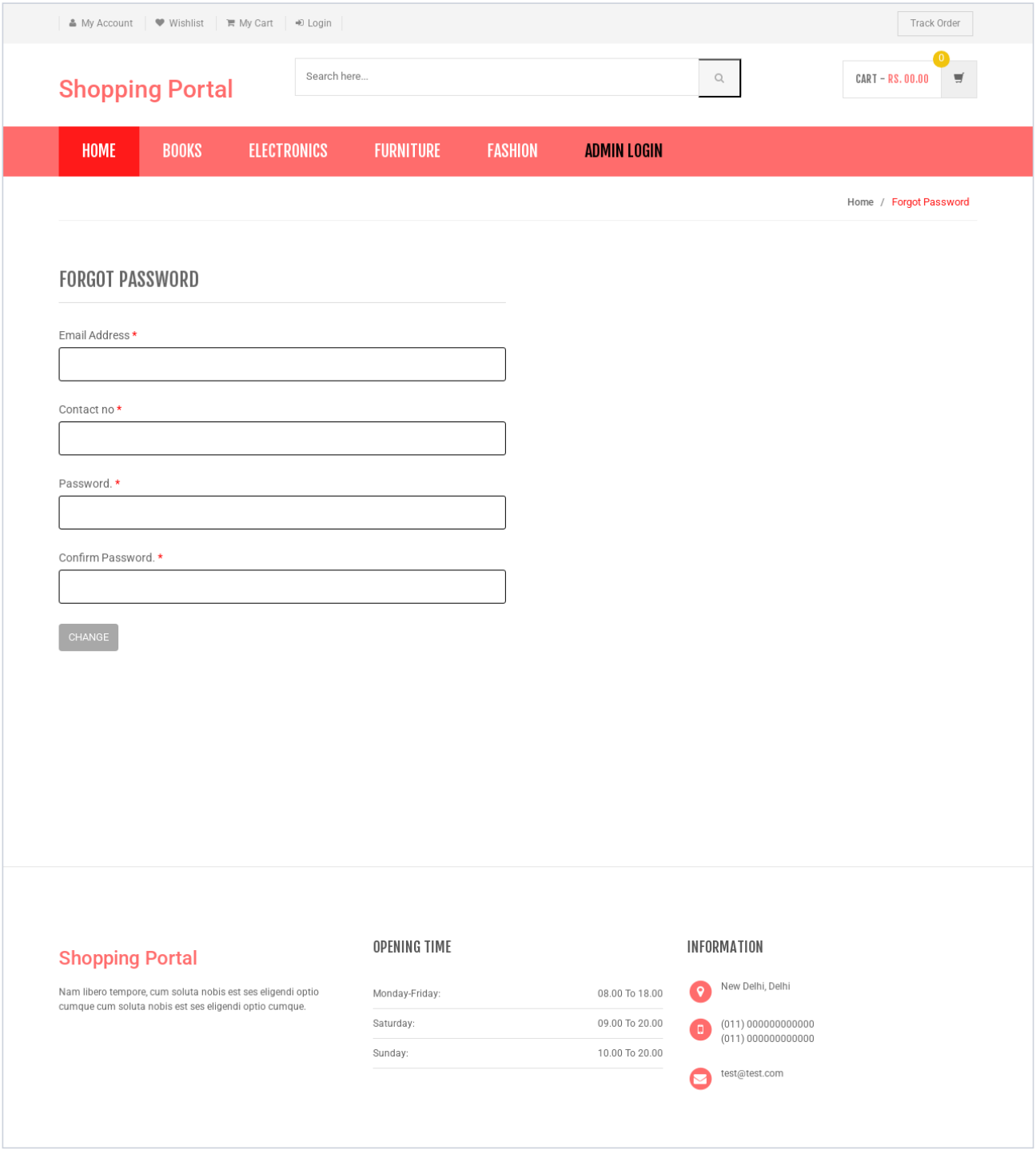


Figure 1 — The public password-reset form (email + contact + new password, no token).

Figure 1 — The public password-reset form (email + contact + new password, no token). Shows the token-less reset mechanism.

Actual Security Impact

Takeover of any customer account (and, combined, access to their orders/PII). The SQLi variant enables a single-request reset of all users.

Exploitation Complexity

Low.

Attack Scenario

Attacker resets a target's password and hijacks the account; or mass-resets all accounts via SQLi.

Remediation

Email a single-use, time-limited, random reset token; never gate reset on guessable PII; parameterize the query.

Secure Code Example

```
$token=bin2hex(random_bytes(32)); // store hashed with expiry, email link; verify token before all
owing a password change
```

Retesting Procedure

On a fixed build, posting email+contact alone must not change any password; a valid token must be required.

References

- CWE-640; OWASP A07
- Evidence: SHOP-011/ (disposable account, deleted)

Final Conclusion

Confirmed on a disposable account (V1/V2; destructive variant intentionally not run). High.

Authorized local-laboratory assessment. Evidence chain sealed (evidence/shopping-portal/SEAL). Draft for human review — not auto-submitted. Secrets/PII in evidence are lab demo data; redact in externally-shared copies.